

Patient Data Taxonomy — Patient360 Secure Clinical Agent

Purpose: a rigorous, exhaustive inventory of every category of data a clinical agent could plausibly touch — used to drive intake form design, consent granularity, and the access-policy layer (the Gate) that governs what the agent is allowed to surface, to whom, and when. Nothing here is real patient data; it's a schema for what the system needs to model.

How to read the sensitivity tiers

Tier	Meaning	Default access rule
T0 — Operational	Needed to run the practice; low individual sensitivity	Visible to any staff role by default
T1 — Clinical standard	Needed for care, moderate sensitivity	Visible to treating clinician + covering clinician only
T2 — Restricted	Special-category under GDPR Art. 9 / nFADP sensitive data; high harm-if-disclosed	Visible to treating clinician only, logged on every read
T3 — Highly restricted	Legal, safety-critical, or maximum-sensitivity; disclosure itself can cause harm	Explicit per-instance authorization required, never included in summaries by default

Every field in an EHR-like system should carry one of these tags. The agent's Gate checks the tag before it checks the question.

1. Identity & Demographic Data — mostly T0/T1

- Legal name, preferred name, date of birth
- Sex assigned at birth, gender identity, pronouns (*gender identity is GDPR/nFADP special-category → T2*)
- National ID / social insurance number, patient ID (internal)
- Residential address, mailing address, phone, email
- Preferred language, interpreter requirement
- Emergency contact / next of kin (name, relationship, contact info)
- Marital/family status, dependents
- Occupation, employer (*T1 — occupation can be clinically relevant, e.g. occupational exposure*)
- Photo ID / patient photo (optional, for identity verification)

2. Administrative, Insurance & Legal Data — T0/T1, some T2

- Insurance provider, policy/group number, coverage tier
- Billing address, payment method, outstanding balance
- Referral source and referring provider
- Legal guardian / power of attorney details (T2)
- Custody or court-mandated care arrangements (T3 — *can itself be safety-sensitive*)
- Advance directives, living will, DNR status (T2)
- Employer-sponsored or third-party payer clauses affecting disclosure

3. Consent & Data Governance Records — T1/T2, foundational to everything below

- Informed consent for treatment (per procedure/episode)
- Consent for data processing (GDPR/nFADP legal basis on file)
- Consent for data sharing — *granular*: which roles, which record categories, which duration
- Consent for research/secondary use (opt-in, revocable)
- Right-to-be-forgotten / erasure requests and their fulfillment status
- Data subject access request (DSAR) history
- Minor status and associated parental-consent rules (T3 — *minor status itself is sensitive*)
- Explicit exclusions ("never disclose X to Y") set by the patient at intake

This category is the one that generates the actual access policy — everything else in this document is data the agent might see; this section is the rules for when it's allowed to.

4. Clinical History (Structured) — T1/T2

- Chief complaint / presenting problem (per encounter)
- History of present illness
- Past medical history: chronic conditions, prior surgeries, hospitalizations
- Family medical history (T2 — *implicates relatives who never consented*)
- Social history: tobacco, alcohol, recreational drug use, living situation, exercise, diet (T2 — *substance use is special-category*)
- Immunization history
- Reproductive/sexual health history (T2)
- Occupational and environmental exposure history

5. Medications & Allergies — T1/T2

- Current medications: name, dose, frequency, prescriber, start date
- Past medications and reason for discontinuation

- Allergies: substance, reaction type, severity, date identified
- Adverse drug reaction history
- Controlled substance prescriptions (*T2/T3 — higher regulatory scrutiny*)
- Medication adherence data (if tracked)

6. Mental & Behavioral Health Data — T2/T3 (this is haiva's core domain)

- Psychiatric diagnoses and diagnostic history (DSM-5/ICD-11 codes)
- Current mental status exam findings
- Risk assessment: suicidality, self-harm history, violence risk (*T3 — maximum sensitivity, maximum care in how the agent handles it*)
- Substance use disorder history and treatment
- Psychometric screening instruments (PHQ-9, GAD-7, PCL-5, etc.) with scores and trend
- Therapy modality, treatment plan, session frequency
- Session notes (SOAP/DAP format)
- Trauma history (*T3*)
- Involuntary treatment or hospitalization history (*T3*)

7. Physical Examination, Vitals & Biometrics — T1, some T2

- Height, weight, BMI
- Vital signs: blood pressure, heart rate, respiratory rate, temperature, SpO2
- Physical exam findings by body system
- Wearable/device data: heart rate variability, sleep, activity, step count
- Voice biomarker data (vocal stress, prosody indicators — relevant to haiva's voice pipeline) (*T2 — biometric identifiers are special-category*)
- Genetic/genomic data, if collected (*T3 — irrevocable, identifies relatives too*)

8. Diagnostic & Laboratory Data — T1/T2

- Laboratory results (bloodwork, urinalysis, etc.) with reference ranges and flags
- Imaging reports (X-ray, MRI, CT, ultrasound) and images themselves
- Pathology and biopsy reports
- Diagnostic codes (ICD-10/ICD-11)
- Genetic test results (*T3 — see above*)
- HIV, STI, and other results with statutorily elevated protection in most jurisdictions (*T3*)

9. Treatment, Care Plans & Procedures — T1/T2

- Active problem list / diagnosis list
- Care plan, treatment goals, prognosis notes

- Procedures performed (date, type, outcome)
- Specialist referrals and their stated reason
- Discharge summaries
- Follow-up scheduling and care coordination notes

10. Communication & Encounter Data — T1/T2

- Appointment history: date, duration, modality (in-person/telehealth)
- Session recordings — audio/video, if consented (*T2/T3 depending on content*)
- Secure patient-provider messages
- Patient portal activity logs (what the patient viewed, when)
- Complaint or grievance records (*T2*)

11. Provenance & Audit Metadata — system-level, governs trust in everything above

- Source of each data point: self-reported, clinician-entered, device-generated, imported from another system
- Capture timestamp, last-modified timestamp, modifying party
- Source reliability/confidence rating (mirrors the EM Source component's self-declared reliability)
- Full access log: who viewed or queried which field, when, and under what stated purpose
- Data retention schedule and scheduled deletion date, per category
- Conflict flags when two sources disagree on the same fact (mirrors the EM Fuser disagreement flag)

*This category isn't patient-facing data — it's data **about** the data, and it's what makes every answer the agent gives auditable rather than asserted.*

12. AI-Derived / Inferred Data — handle as a distinct class, always labeled as inference

- AI-generated encounter summaries
- Predictive risk scores or flags
- Clinical decision-support suggestions
- Emotion/sentiment or vocal-affect analysis output
- Any agent-synthesized "picture" combining multiple sources into one narrative

Design rule carried over from haiva/EM: inferred data must never be stored or displayed as if it were a stated fact. It's tagged as derived, carries its own confidence tier, and is the one category where a hallucination would be invisible if not kept structurally separate from row 4-10's stated data.

Sensitivity tiering — summary view

Category	Default tier	Notes
Identity/Demographic	T0-T1	Gender identity → T2
Administrative/Insurance	T0-T1	Guardianship/custody → T2-T3
Consent records	T1-T2	Governs access to everything else
Clinical history	T1-T2	Family history, sexual/substance history → T2
Medications/Allergies	T1-T2	Controlled substances → T2-T3
Mental/behavioral health	T2-T3	Risk/suicidality always T3
Vitals/Biometrics	T1-T2	Genetic, voice biomarkers → T2-T3
Diagnostics/Labs	T1-T2	Genetic, HIV/STI → T3
Treatment/Care plans	T1-T2	—
Communication/Encounter	T1-T2	Recordings → T2-T3
Provenance/Audit	System-level	Not patient-facing but access-controlled itself
AI-derived/Inferred	Inherits source tier, min. T2	Never displayed unlabeled

What this means for Patient360's design

1. **Every field needs a tier at ingestion, not at query time.** Tagging happens at intake (or at import), so the Gate has something to check against the moment a question is asked — this is what makes "controlling the agent" structural rather than a prompt instruction.
2. **T3 data needs its own rule, not just a stricter version of T2's rule.** Suicidality/risk data, genetic data, and custody/legal status are the fields most likely to cause real harm if surfaced to the wrong role — they warrant explicit, named authorization per access, not a role-based default.
3. **Provenance (category 11) is what turns "the agent said X" into "here's why the agent said X, from what, and who could see that it was asked."** This is the category that answers the compliance-audit scenario directly.
4. **Category 12 (AI-derived) is the highest-risk category to get wrong,** because a confident-sounding inference is indistinguishable from a stated fact to a time-pressed

clinician unless the system enforces the separation visually and structurally — not just in a disclaimer.